

Security+ 2.4 · Wireless Attacks

Mestre CyberSec · Aula 2.4 — Wireless Attacks (7:55) · [Assistir Vídeo no YouTube](#) ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Wi-Fi attacks: deauthentication/deassociation (desconecta clientes mandando frame falsificado — aí o cliente reconecta no evil twin); evil twin (AP falso com SSID igual); RF jamming (corta o rádio inteiro); bluesnarfing/bluejacking (Bluetooth). Defesa: WPA3/SAE, detectar AP clone

💡 Highlights que a prova CompTIA cobra

- Evil twin: AP falso com a MESMA SSID — captura o handshake
- Deauth: desconecta clientes pra eles caírem no evil twin
- WPA3/SAE protege o handshake contra captura de senha

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'fake access point mimics legitimate one' = evil twin
- 'disconnects wireless clients' = deauthentication attack

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Ataque de Desautenticação (Deauth)

Ataque DoS sem fio que envia quadros de gerenciamento 802.11 falsificados para desconectar clientes de um AP legítimo, forçando-os a se reconectar, geralmente a um evil twin controlado pelo atacante.

⚠ Armadilha CompTIA: *If the question says 'disconnects wireless clients' or 'spoofed management frame,' it is a deauthentication attack. Remember: deauth = management frame, not data frame.*

• Evil Twin (Gêmeo Maligno) (N/A)

Um ponto de acesso sem fio clandestino configurado com o mesmo SSID de uma rede legítima para atrair clientes a se associarem, permitindo roubo de credenciais (captura de handshake) e ataques man-in-the-middle.

⚠ Armadilha CompTIA: *Exam trigger — 'fake access point that mimics a legitimate one' = evil twin. Combine with deauth: deauth kicks clients off, evil twin catches them when they reconnect.*

• Interferência de Rádio (RF Jamming)

Ataque de negação de serviço que emite ruído de radiofrequência forte no mesmo espectro da rede sem fio, sobrecarregando o sinal e impedindo a comunicação legítima.

⚠ Armadilha CompTIA: *Jamming = DoS at Layer 1 (physical). Distinguish from deauthentication, which works at Layer 7 using legitimate management frames. Both are DoS, but jamming is raw RF interference.*

• Bluesnarfing (N/A)

Ataque que explora vulnerabilidades do Bluetooth para obter acesso não autorizado ao dispositivo e roubar dados como contatos, calendários e funções sem o conhecimento do usuário.

⚠ Armadilha CompTIA: *Bluesnarfing = DATA theft (snarf = steal). Do not confuse with bluejacking, which only sends unsolicited messages. If the question mentions stolen data over Bluetooth, it is bluesnarfing.*

• Bluejacking (N/A)

Envio de mensagens ou cartões de visita não solicitados para dispositivos Bluetooth próximos como uma técnica de spam ou DoS via Bluetooth — não envolve roubo de dados.

⚠ Armadilha CompTIA: *Bluejacking = unsolicited MESSAGES (jacking = jab). No data is taken. Compare to bluesnarfing (data theft) and bluebugging (full remote control of the device).*

• WPA3 com SAE (Autenticação Simultânea de Iguais) (WPA3 / SAE)

Padrão moderno de segurança Wi-Fi que substitui o handshake de 4 vias do WPA2 pelo SAE, uma troca de chaves baseada em Dragonfly que resiste a ataques de dicionário offline mesmo que o handshake seja capturado.

⚠ Armadilha CompTIA: *Exam trigger — 'protects against offline brute-force / handshake capture' = WPA3/SAE. SAE uses a password-authenticated key exchange (PAKE); each session derives a unique key.*

• Ponto de Acesso Clandestino (AP Rogue) (Rogue AP)

Qualquer ponto de acesso sem fio não autorizado conectado à rede corporativa, instalado intencionalmente ou acidentalmente por um insider, criando uma porta dos fundos para a infraestrutura cabeada.

⚠ Armadilha CompTIA: *Rogue AP ≠ Evil Twin. Rogue AP = plugged into the corporate LAN without approval (insider threat). Evil Twin = wireless mimicry with same SSID to attack clients. The exam distinguishes these carefully.*

• Handshake de 4 Vias (4-Way Handshake)

Processo de autenticação WPA/WPA2 em que o AP e o cliente trocam quatro mensagens EAPOL para derivar a mesma PTK (Chave Transitória de Par) para tráfego criptografado.

⚠ Armadilha CompTIA: *Exam focus: the 4-way handshake can be captured by an evil twin and cracked offline with a dictionary attack — this is precisely why WPA3/SAE was introduced.*

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista do SOC revisa os logs do controlador wireless e vê centenas de quadros de gerenciamento 802.11 falsificados chegando com o endereço MAC do AP corporativo legítimo, cada um destinado a uma estação cliente diferente. Segundos depois, vários notebooks se associam a um access point que não está no inventário autorizado. Qual técnica de ataque explica melhor as desconexões repentinas?

- A) Um flood de desautenticação que força os clientes a perderem a associação para se reconectarem a um AP controlado pelo atacante
- B) Jamming de RF que satura o canal e impede a decodificação de qualquer quadro 802.11
- C) Bluejacking que envia quadros não solicitados para notebooks próximos com Bluetooth habilitado
- D) Captura passiva do handshake de 4 vias para derivar a chave transitória de par

QUESTÃO 2 · CENÁRIO DE EXAME

Usuários da ala leste relatam que seus notebooks mostram sinal wireless forte, mas não conseguem manter associação com nenhum SSID, e até um hotspot pessoal de celular não funciona. Um analisador de espectro mostra um piso de ruído muito elevado nas faixas de 2,4 GHz e 5 GHz, sem quadros 802.11 decodificáveis na área afetada. Que tipo de ataque está ocorrendo?

- A) Flood de desautenticação direcionado ao controlador corporativo
- B) Jamming de RF que interfere no próprio espectro de radiofrequência
- C) Access point evil twin anunciando o SSID corporativo
- D) Bluesnarfing de dados de contatos de dispositivos móveis próximos

QUESTÃO 3 · CENÁRIO DE EXAME

Participantes de uma conferência se conectam a um SSID chamado ConfGuest que parece idêntico à rede oficial. O portal cativo então solicita credenciais de e-mail corporativo. Depois, a equipe de rede encontra um segundo rádio próximo com o mesmo SSID, sinal mais forte, BSSID diferente e um roteador doméstico como hardware. Qual ataque está descrito?

- A) Ataque de desautenticação contra os access points da conferência
- B) Bluejacking por meio de emparelhamento Bluetooth não autenticado
- C) Access point evil twin usado para coletar credenciais por meio de portal falso
- D) Jamming de RF que força os clientes a mudar para um canal concorrente

QUESTÃO 4 · CENÁRIO DE EXAME

Um funcionário relata que nada incomum apareceu em seu celular, mas uma revisão de segurança depois descobre que a lista de contatos e os compromissos da agenda foram copiados do dispositivo por alguém que estava por perto no refeitório. O aparelho estava com Bluetooth habilitado e havia sido emparelhado com um fone pessoal mais cedo naquele dia. Qual ataque Bluetooth provavelmente ocorreu?

- A) Bluejacking, que envia cartões de visita não solicitados para dispositivos próximos
- B) Bluesnarfing, que extrai ilicitamente dados como contatos e compromissos de agenda via Bluetooth
- C) Desautenticação, que forja quadros de gerenciamento 802.11 para romper o emparelhamento
- D) Jamming de RF, que satura a piconet Bluetooth com ruído

QUESTÃO 5 · CENÁRIO DE EXAME

Durante uma inspeção, vários funcionários no saguão mostram ao analista de segurança mensagens de texto e vCards não solicitados que apareceram em seus celulares via Bluetooth. Os funcionários nunca aceitaram um pedido de emparelhamento, e a análise forense confirma que nenhum arquivo ou dado pessoal saiu dos dispositivos. Que atividade Bluetooth é essa?

- A) Bluesnarfing de dados de contatos e agenda
- B) Impersonação evil twin de um hotspot de operadora móvel
- C) Jamming de RF da piconet Bluetooth
- D) Bluejacking, que envia mensagens não solicitadas para dispositivos visíveis

QUESTÃO 6 · CENÁRIO DE EXAME

Uma avaliação mostra que um atacante no perímetro desconecta um cliente wireless, captura o handshake de 4 vias do WPA2-PSK, leva o material para fora e executa um ataque de dicionário offline contra a frase-senha compartilhada. Qual mudança elimina mais diretamente a possibilidade desse ataque de quebra offline?

- A) Migrar a WLAN para WPA3 com Simultaneous Authentication of Equals
- B) Desabilitar a transmissão do SSID em todos os access points corporativos
- C) Habilitar filtragem por endereço MAC no controlador wireless
- D) Reduzir a potência de transmissão dos access points para diminuir a área de cobertura

QUESTÃO 7 · CENÁRIO DE EXAME

Após uma atualização wireless, um engenheiro percebe que quadros de desautenticação forjados por uma ferramenta de teste não derrubam mais os clientes conectados, e os sensores de intrusão os registram como descartados. Qual recurso do padrão atualizado explica esse comportamento?

- A) Simultaneous Authentication of Equals
- B) Inscrição por botão do Wi-Fi Protected Setup
- C) Protected Management Frames, definido no 802.11w
- D) Rotação de chave pré-compartilhada em intervalo fixo

QUESTÃO 8 · CENÁRIO DE EXAME

Uma equipe de segurança precisa detectar access points não autorizados operando no campus corporativo, incluindo dispositivos que anunciam um SSID parecido com o corporativo ao lado da infraestrutura legítima. Qual controle é mais eficaz para esse objetivo?

- A) Desabilitar a transmissão de SSID em todos os access points corporativos
- B) Um IPS wireless que compara continuamente os rádios detectados com um inventário de APs autorizados
- C) Habilitar filtragem por endereço MAC no controlador wireless
- D) Atribuir endereços IP estáticos a todos os dispositivos clientes corporativos

QUESTÃO 9 · CENÁRIO DE EXAME

Funcionários se conectam repetidamente a um access point fraudulento que clona o SSID corporativo e, em alguns casos, digitam suas credenciais de domínio em um portal parecido com o legítimo. Qual controle permite melhor que os dispositivos clientes rejeitem o AP ilegítimo durante a autenticação, antes que qualquer credencial seja exposta?

- A)** Ocultar o SSID corporativo dos quadros beacon
- B)** Uma lista de permissões de endereços MAC de clientes no controlador wireless
- C)** WPA2-PSK com frase-senha forte rotacionada mensalmente
- D)** WPA3-Enterprise com 802.1X/EAP-TLS e validação obrigatória do certificado do servidor pelos clientes

QUESTÃO 10 · CENÁRIO DE EXAME

Um funcionário conecta um roteador wireless pessoal em uma tomada Ethernet de parede sem uso para melhorar a cobertura em uma sala de conferências. O dispositivo anuncia um SSID semelhante ao da rede corporativa e distribui concessões DHCP para clientes próximos, contornando os controles de segurança wireless da organização. Qual controle impede mais eficazmente que esse dispositivo conceda acesso à rede?

- A)** Aplicar autenticação por porta 802.1X com controle de acesso à rede em todas as portas de acesso dos switches
- B)** Configurar filtragem por endereço MAC em cada porta de acesso dos switches
- C)** Desabilitar a transmissão de SSID nos access points corporativos
- D)** Habilitar WPA3-SAE na rede wireless corporativa

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Um flood de desautenticação que força os clientes a perderem a associação para se reconectarem a um AP controlado pelo atacante

Ataques de desautenticação/desassociação enviam quadros de gerenciamento 802.11 forjados usando o MAC do AP legítimo, fazendo os clientes acreditarem que o AP encerrou a sessão. As vítimas se reconectam automaticamente, e é exatamente isso que torna esse ataque o precursor padrão de um evil twin. O jamming de RF corrompe o meio com ruído em vez de quadros de gerenciamento válidos, o bluejacking é um incômodo de mensagens Bluetooth que nunca desconecta clientes Wi-Fi, e capturar passivamente o handshake de 4 vias coleta material para quebra offline, mas não desassocia ninguém.

Questão 2: Alternativa B — Jamming de RF que interfere no próprio espectro de radiofrequência

O piso de ruído elevado sem quadros 802.11 decodificáveis é a assinatura do jamming de RF, que transmite energia deliberadamente nas mesmas frequências para negar o meio a todos os dispositivos no alcance, incluindo APs legítimos e hotspots pessoais. Um flood de desautenticação ainda produz quadros de gerenciamento aparentemente válidos e afeta apenas clientes associados a um AP específico. Um evil twin atrai clientes em vez de bloquear o espectro, e o bluesnarfing é uma técnica de roubo de dados via Bluetooth sem relação com ruído de rádio Wi-Fi.

Questão 3: Alternativa C — Access point evil twin usado para coletar credenciais por meio de portal falso

Um evil twin é um AP rogue que copia um SSID legítimo (muitas vezes com sinal mais forte e BSSID diferente) para atrair clientes a se conectarem à infraestrutura controlada pelo atacante, onde portais cativos, redirecionamento de DNS ou interceptação on-path podem capturar credenciais. A desautenticação apenas desconecta clientes, o bluejacking é spam via Bluetooth, e o jamming nega o meio em vez de se passar por uma rede para coletar dados do usuário.

Questão 4: Alternativa B — Bluesnarfing, que extrai ilicitamente dados como contatos e compromissos de agenda via Bluetooth

O bluesnarfing é a obtenção não autorizada de informações como contatos, agendas e mensagens de um dispositivo com Bluetooth, normalmente quando ele está visível e vulnerável. O bluejacking apenas envia mensagens não solicitadas e não extrai dados. Desautenticação é um conceito de Wi-Fi 802.11, e o jamming de RF causaria perda de conectividade e interferência perceptível, não uma cópia silenciosa de dados.

Questão 5: Alternativa D — Bluejacking, que envia mensagens não solicitadas para dispositivos visíveis

O bluejacking é a prática de enviar mensagens não solicitadas, frequentemente vCards, para dispositivos Bluetooth ao alcance, sem retirar dados deles. Como nenhum dado foi extraído, o bluesnarfing não se aplica. Evil twin é uma técnica de impersonação de access point Wi-Fi, e jamming de RF é interferência deliberada, não mensagens.

Questão 6: Alternativa A — Migrar a WLAN para WPA3 com Simultaneous Authentication of Equals

O WPA3 usa o SAE (Dragonfly), uma troca de chaves autenticada que oferece sigilo perfeito futuro e resiste a ataques de dicionário offline sobre a troca capturada, então o atacante que grava o handshake não consegue testar frases-senha offline. Ocultar o SSID, filtrar MAC e reduzir potência são controles fracos de obscurificação ou de acesso que não alteram a exposição criptográfica do WPA2-PSK.

Questão 7: Alternativa C — Protected Management Frames, definido no 802.11w

Os Protected Management Frames (802.11w), obrigatórios no WPA3 e opcionais no WPA2, protegem criptograficamente quadros de gerenciamento unicast e broadcast, como desautenticação e desassociação, de modo que quadros falsificados são rejeitados por clientes e APs. O SAE protege a troca de chaves de autenticação, o WPS é um recurso legado de conveniência com fraquezas conhecidas, e a rotação de PSK não protege quadros de gerenciamento.

Questão 8: Alternativa B — Um IPS wireless que compara continuamente os rádios detectados com um inventário de APs autorizados

Um IPS wireless com uma linha de base precisa de APs, BSSIDs e canais autorizados detecta rádios novos ou falsificados em tempo real e alerta sobre dispositivos rogue e evil twin. Desabilitar a transmissão de SSID oculta o nome, mas não detecta rádios não autorizados; a filtragem MAC no controlador é um controle de acesso fraco e sujeito a spoofing; e endereçamento estático não resolve APs rogue que executam seu próprio serviço DHCP.

Questão 9: Alternativa D — WPA3-Enterprise com 802.1X/EAP-TLS e validação obrigatória do certificado do servidor pelos clientes

Com 802.1X/EAP-TLS, o cliente e o servidor de autenticação se autenticam mutuamente por certificados, então um cliente que valida o certificado do servidor falhará no handshake com um evil twin que não pode apresentar um certificado confiável. Ocultar o SSID e listas de permissão de MAC são controles fracos de obscurecimento facilmente contornados, e uma PSK compartilhada é conhecida por todos os usuários e pelo atacante que a coleta, não permitindo distinguir o AP legítimo de um clone.

Questão 10: Alternativa A — Aplicar autenticação por porta 802.1X com controle de acesso à rede em todas as portas de acesso dos switches

A autenticação por porta 802.1X com NAC exige que o dispositivo conectado se autentique na rede antes que qualquer tráfego seja encaminhado, então um roteador pessoal não gerenciado conectado à tomada de parede nunca obtém acesso e não consegue fazer a ponte de clientes wireless para a LAN corporativa. Filtragem MAC e SSID oculto são facilmente contornados, e o WPA3-SAE protege apenas o enlace wireless corporativo; não faz nada contra um AP rogue ligado a uma porta cabeada.